

INTERNAL SECURITY AUDIT — BOTIUM TOYS

Simulated Google Cybersecurity Professional Certificate project | Taaha Idrees

Executive summary

Simulated training audit of fictional Botium Toys, based on the Google Cybersecurity Professional Certificate activity. The provided scenario reports a risk score of 8/10. This is a document-based checklist assessment, not independent technical testing or a formal compliance certification.

Scope and method

Scope covers the company security program, employee devices, network, systems, data, physical facilities, e-commerce, inventory, and legacy systems. Answers reflect explicit scenario statements and documented weaknesses. YES indicates the control or checklist practice is described as present; it does not necessarily establish effectiveness.

Key findings

7 of 14 security controls are marked YES and 7 NO. The 12 course compliance checklist items have 4 YES and 8 NO. Missing controls include least privilege, separation of duties, encryption, backups, disaster recovery planning, IDS, and centralized password management. Existing password policies and legacy maintenance have identified weaknesses.

Assessment completion

Completed all 26 assessment items for the Botium Toys Internal Security Audit, including 14 security control assessments and 12 compliance assessments covering PCI DSS, GDPR, and SOC. Documented findings, identified security gaps, and developed remediation recommendations based on the provided case study.

Assessment scope and limitations

All findings are based on the fictional course scenario and its supplied documents; no scans, interviews, log reviews, or live systems were examined.

Security controls assessment

Control	Status	Evidence / qualification
Least privilege	NO	Not implemented; broad employee access to internally stored data.
Disaster recovery plans	NO	No disaster recovery plan exists.
Password policies	YES	Policy exists, but requirements are weak.
Separation of duties	NO	Not implemented.
Firewall	YES	Firewall uses defined traffic-filtering rules.
Intrusion detection system (IDS)	NO	IDS has not been installed.
Backups	NO	No backups of critical data.
Antivirus software	YES	Installed and regularly monitored.

Control	Status	Evidence / qualification
Legacy system monitoring and maintenance	YES	Monitoring and maintenance occur; no regular schedule and intervention methods unclear.
Encryption	NO	Credit card information is not protected with encryption.
Password management system	NO	No centralized system enforcing minimum password requirements.
Physical locks	YES	Sufficient locks at offices, storefront and warehouse.
CCTV surveillance	YES	Up-to-date CCTV surveillance is present.
Fire detection and prevention	YES	Functioning fire detection and prevention systems are present.

Compliance checklist assessment

Area	Course best practice	Status	Evidence
PCI DSS	Only authorized users access cardholder information	NO	Broad employee access; least privilege absent.
PCI DSS	Payment information handled in a secure environment	NO	Encryption and access restrictions are missing.
PCI DSS	Encryption procedures protect payment data	NO	Encryption not used for cardholder information.
PCI DSS	Secure password management policies	NO	Weak password requirements and no centralized enforcement.
GDPR	EU customer data is kept private and secure	NO	Excessive access and inadequate data protection.
GDPR	72-hour notification plan for EU customers	YES	The scenario confirms a notification plan; this is not a complete legal GDPR assessment.
GDPR	Data classified and inventoried	NO	Asset identification and classification require improvement.
GDPR	Privacy policies and processes enforced	YES	Privacy policies and processes developed and enforced.
SOC	User access policies established	NO	Adequate access restrictions not implemented.
SOC	Sensitive PII/SPII kept confidential	NO	Broad access and insufficient safeguards.
SOC	Data integrity maintained	YES	Report states integrity controls are in place.
SOC	Data available to authorized individuals	YES	Report states availability has been ensured.

Prioritized recommendations

Priority	Area	Action
Critical	Restrict sensitive data access	Apply least privilege, role-based access control, and separation of duties; review permissions.
Critical	Protect payment information	Implement appropriate encryption in transit and at rest, with secure key management.
High	Prepare for disruption	Create and test disaster recovery procedures; maintain protected, restorable backups.
High	Improve authentication	Strengthen password requirements and implement centralized policy enforcement; consider MFA.
Medium	Improve detection	Deploy and tune an IDS with documented alert review and response procedures.
Medium	Manage assets and legacy systems	Inventory/classify assets; schedule legacy-system maintenance and document intervention steps.

Supplied source materials

- Portfolio Activity: Conduct a security audit (course instructions)
- Botium Toys: Scope, goals, and risk assessment report
- Control categories (course reference)
- Controls and compliance checklist (course template)

Note: This checklist is not a formal PCI DSS, GDPR, or SOC compliance determination.